

NIST AI 100-2: Adversarial Machine Learning Taxonomy

A Taxonomy and Terminology of Attacks and Mitigations across the Artificial Intelligence Lifecycle

NIST Special Publication AI 100-2 (Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations) provides the official federal terminology and taxonomy for evaluating attacks against AI and predictive/generative ML systems. It categorizes attacks by lifecycle phase (training vs testing/deployment), attacker goals (integrity, availability, confidentiality, privacy), and adversary knowledge (white-box, gray-box, black-box).

1. Taxonomy of Adversarial ML Attacks

NIST AI 100-2 structures adversarial attacks into four fundamental classes based on the attacker's primary objective:

- **Evasion Attacks (Inference Phase):** Modifying inputs at test time to cause the model to make misclassifications or generate incorrect outputs, while preserving human semantic perception.
- **Poisoning Attacks (Training Phase):** Corrupting training datasets or fine-tuning pipelines to introduce targeted inaccuracies, degrade global accuracy, or implant stealthy backdoors.
- **Privacy Attacks (Lifecycle-wide):** Inferring sensitive information about the training data, training individuals, or internal parameters through statistical probing of model outputs.
- **Abuse and Exploitation Attacks (Deployment Phase):** Repurposing the AI system to generate malicious content, execute denial of service, or hijack autonomous agent capabilities.

2. Evasion Attacks and Adversarial Perturbations

Evasion attacks represent the most studied vulnerability in machine learning inference:

- **Mathematical Foundations:** Given an input x and model $f(x)$, an attacker computes a perturbation δ within an L -infinity or L_2 norm bound $\|\delta\| \leq \epsilon$ such that $f(x + \delta) \neq f(x)$, while $x + \delta$ appears indistinguishable from x to human observers.
- **Gradient-Based Attacks (White-Box):** Techniques such as Fast Gradient Sign Method (FGSM) and Projected Gradient Descent (PGD) compute adversarial perturbations using backpropagation through the model's loss gradient.
- **Black-Box Query Attacks:** In the absence of model gradients, attackers use zeroth-order optimization or transferability attacks where adversarial examples crafted on a surrogate model successfully transfer to the target model.
- **GenAI Adversarial Suffixes:** In Large Language Models, optimization algorithms (such as Greedy Coordinate Gradient - GCG) discover adversarial token sequences appended to malicious prompts that reliably bypass safety guardrails.

3. Poisoning, Trojans, and Backdoor Attacks

Poisoning attacks undermine the foundational integrity of the learned representation:

- **Availability Poisoning:** Injecting random or maximal-loss noise into training data to degrade overall model convergence, rendering the model ineffective for all users (Denial of ML Service).
- **Targeted Integrity Poisoning:** Injecting carefully crafted samples that alter predictions only for specific target classes while preserving high validation accuracy across normal inputs.

- Trojan / Backdoor Implantation: Embedding a specific trigger pattern (e.g., a pixel patch in computer vision, or a rare unicode character in NLP). The model behaves normally on all benign inputs, but when the trigger is present, it forces a predetermined adversarial output.
- Clean-Label Poisoning: Designing poisoned samples that possess legitimate ground-truth labels according to human reviewers, but feature subtle adversarial perturbations in the feature space that misalign learned decision boundaries.

4. Privacy Attacks: MIA, Model Inversion, and Extraction

Machine learning models often memorize training data, creating critical privacy vulnerabilities:

- Membership Inference Attacks (MIA): An attacker determines whether a specific target record was used in the training dataset by comparing the model's prediction confidence, loss, and entropy against threshold values. Overfitted models are exceptionally vulnerable.
- Model Inversion Attacks: An attacker reconstructs recognizable training features (e.g., reconstructing recognizable human faces from a facial recognition model) by optimizing input representations to maximize target class confidence scores.
- Training Data Extraction in LLMs: Generating prompts designed to exploit memorization in Large Language Models, extracting verbatim credit card numbers, social security numbers, medical histories, or proprietary source code.
- Model Extraction (Theft): Reconstructing the weights, architecture, or functional decision boundaries of a proprietary model by querying its API with synthetic inputs and training a student model on the returned output probabilities.

5. Defensive Controls and Mitigations Taxonomy

NIST AI 100-2 categorizes technical mitigations designed to counter adversarial threats:

- Adversarial Training: Augmenting the training dataset with adversarially perturbed samples generated during training (min-max optimization), drastically improving empirical robustness against evasion.
- Differential Privacy (DP-SGD): Adding calibrated noise to gradients during training to provide mathematical guarantees that no individual training sample's presence can be confidently inferred, mitigating MIA and data extraction.
- Data Provenance and Cryptographic Verification: Implementing strict cryptographic signatures, hash manifests, and data lineage tracking for all training datasets, fine-tuning sets, and third-party weights.
- Certified Robustness and Randomized Smoothing: Providing mathematically verifiable guarantees on prediction invariance within defined perturbation radii.
- Anomaly Detection & Input Preprocessing: Utilizing autoencoders, feature squeezing, and semantic perplexity filters to detect and sanitize out-of-distribution adversarial inputs prior to inference.